Network Detection and Response

Đinh Quốc Thịnh - 24521675

Trần Đình Nguyên - 24521208

Lê Xuân Nguyên - 24520021

An toàn mạng máy tính nâng cao - NT534.R11.ANTN

1. Bối cảnh và các thách thức trong NDR

Các hệ thống giám sát mạng chỉ dựa vào IDS theo chữ ký (signature-based) cho ra cảnh báo rời rạc, thiếu ngữ cảnh, và bỏ sót các hành vi không có chữ ký như beaconing C2, DNS tunneling hay lateral movement dùng công cụ hợp lệ. Lưu lượng mã hoá TLS ngày càng lớn càng làm giảm hiệu quả của việc so khớp payload.

Painpoint	Mô tả
1. Visibility	IDS chỉ ghi lại gói tin khớp rule; không có bản ghi đầy đủ về kết nối, DNS, HTTP, TLS, file truyền qua mạng nên khó threat hunting và điều tra ngược.
2. Detection	Phát hiện phụ thuộc chữ ký, bỏ sót tấn công dựa trên hành vi (scan chậm, beaconing, exfiltration qua DNS); không rõ cuộc tấn công đang ở giai đoạn nào của kill chain.
3. Response	Phản hồi dừng ở cảnh báo; việc chặn IP, cô lập host vẫn làm thủ công, làm kéo dài thời gian từ phát hiện đến ngăn chặn.
4. Processing procedure	Log từ nhiều nguồn nằm rời rạc, khác định dạng, khó tương quan một sự kiện giữa IDS và log hành vi; chưa có playbook xử lý chuẩn.
5. Human resource	Số lượng cảnh báo lớn gây alert fatigue; analyst thiếu kỹ năng đọc log mạng và ánh xạ sự kiện lên MITRE ATT&CK.

2. Xu hướng công nghệ và lý do chọn Zeek

Xu hướng NDR hiện nay là kết hợp **metadata mạng đầy đủ** (để hunting và phát hiện theo hành vi) với **chữ ký** (để bắt exploit đã biết), rồi tự động hoá phản hồi. Zeek đáp ứng phần metadata và phát hiện hành vi; Suricata giữ vai trò signature.

Painpoint	Hướng giải quyết	Thành phần đảm nhận
Visibility	Ghi lại mọi phiên kết nối và giao thức thành log có cấu trúc, hiển thị trên dashboard hợp nhất	Zeek, Kibana
Detection	Phát hiện theo hành vi bằng Zeek script (SumStats, Notice), đối chiếu threat intel, kết hợp chữ ký Suricata; ánh xạ MITRE ATT&CK	Zeek, Suricata, Elastic Security
Response	Script tự động chặn IP trên firewall và gửi thông báo khi rule mức High/Critical được kích hoạt	Python, pfSense/CrowdSec, Teams/Telegram
Processing procedure	Tập trung log về ELK, chuẩn hoá theo ECS, tương quan Zeek–Suricata qua Community ID; xây dựng playbook	Filebeat, Elasticsearch
Human resource	Dashboard theo MITRE ATT&CK, playbook và tài liệu hướng dẫn hunting trên log Zeek	Kibana, tài liệu nội bộ

Vì sao chọn Zeek làm lõi thay cho chỉ dùng Suricata:

- **Log giao thức phong phú:** sinh sẵn `conn.log`, `dns.log`, `http.log`, `ssl.log`, `files.log`, `smb_files.log`, `smb_mapping.log`, `dce_rpc.log`, `ssh.log`, `ftp.log`... mỗi phiên đều có `uid` để nối các log với nhau.
- **Ngôn ngữ script hướng sự kiện:** viết logic phát hiện theo hành vi (đếm, ngưỡng, chuỗi sự kiện) mà rule chữ ký khó diễn đạt; framework SumStats và Notice có sẵn.
- **Intelligence Framework:** đối chiếu IP, domain, URL, hash file với danh sách IOC, sinh `intel.log`.
- **Làm việc tốt với lưu lượng mã hoá:** dù không giải mã, vẫn có SNI, chứng chỉ, JA3/JA4 (qua package) để nhận diện client/C2.

- **Hệ sinh thái tích hợp:** Filebeat có module Zeek và Suricata; Community ID giúp ghép cảnh báo Suricata với log Zeek của cùng một flow.

3. Mục tiêu đồ án

Đồ án hướng tới một hệ thống NDR hoàn chỉnh từ thu thập, phát hiện đến phản hồi, chứng minh qua 6 kịch bản tấn công thực tế.

1. **Visibility:** Triển khai Zeek trên cổng mirror (SPAN) để ghi lại toàn bộ metadata lưu lượng nội bộ; xây dựng dashboard Kibana hiển thị kết nối, DNS, HTTP, TLS, SMB và file theo thời gian, nguồn, đích.
2. **Detection:** Viết bộ Zeek script phát hiện theo hành vi (scan, brute force, DNS tunneling, beaconing, lateral movement SMB) và tích hợp Intel Framework; bổ sung Suricata cho phát hiện theo chữ ký.
3. **MITRE ATT&CK mapping:** Gắn tactic và technique cho từng notice/alert, xây dựng dashboard theo ATT&CK để xác định giai đoạn tấn công.
4. **Response:** Phát triển script Python đọc alert từ Elasticsearch, tự động chặn IP tấn công trên pfSense/CrowdSec và gửi thông báo qua email, Microsoft Teams hoặc Telegram.
5. **Quy trình và con người:** Xây dựng playbook xử lý cho từng kịch bản và tài liệu hướng dẫn threat hunting trên log Zeek cho analyst.

4. Các yêu cầu

4.1 Business requirements

No.	Requirement	Chi tiết
1	Visibility attacks	Thu thập log Zeek (conn, dns, http, ssl, files, smb, dce_rpc, notice, intel) và Suricata eve.json; dashboard Kibana hiển thị thời gian, nguồn gốc, đích và hành vi
2	Detect attacks	Phát hiện: port scan, brute force SSH/FTP, malware download theo IOC, lateral movement qua SMB/PsExec, C2 beaconing, data exfiltration qua DNS

No.	Requirement	Chi tiết
3	MITRE mapping	Mỗi notice/alert có trường `mitre.tactic` và `mitre.technique`; dashboard thống kê theo tactic/technique
4	Response attacks	Tự động chặn IP tấn công trên firewall và gửi thông báo qua email, Teams/Telegram; có cơ chế whitelist và tự gỡ chặn sau thời gian cấu hình
5	Hunt attacks	Truy vết theo `uid` và Community ID để dựng lại chuỗi sự kiện của một cuộc tấn công
6	Incident procedure	Playbook gồm: phát hiện → phân loại → ngăn chặn → điều tra → báo cáo cho từng kịch bản
7	Human resource	Tài liệu đào tạo hunting trên log Zeek và sử dụng dashboard MITRE ATT&CK

4.2 Non-business requirements

Các con số dưới đây là đề xuất cho quy mô triển khai thật; môi trường demo chỉ cần cấu hình ở dòng Computing (test).

Hạng mục	Yêu cầu
Business volume	Y1: 10–50 doanh nghiệp, 5–20 người dùng đồng thời; Y2: 100–200 doanh nghiệp, 50–150 người dùng; Y3: 400–500 doanh nghiệp, 300–350 người dùng
Computing (test)	VM Zeek + Suricata sensor: 4 vCPU, 8 GB RAM, 2 NIC (1 management, 1 sniff); VM ELK: 6 vCPU, 8–12 GB RAM; các VM attacker/victim: 2 vCPU, 2–4 GB RAM
Computing (production)	Zeek chạy cluster mode (manager, proxy, nhiều worker) với AF_PACKET; Elasticsearch tối thiểu 3 node; tăng worker và node theo băng thông giám sát
Performance	Tỉ lệ rớt gói trên sensor dưới 1% (theo `capture_loss.log`); độ trễ từ lúc tấn công đến khi có thông báo dưới 1 phút

Hạng mục	Yêu cầu
Storage	Lưu log tối thiểu 12 tháng: Hot 7–30 ngày (SSD), Warm 1–3 tháng, Cold 3–12 tháng (ổ chi phí thấp); quản lý bằng ILM của Elasticsearch
Security	Kết nối Filebeat → Elasticsearch dùng TLS; phân quyền Kibana theo vai trò; API key của firewall lưu ngoài mã nguồn
Availability	Sensor tự khởi động lại khi lỗi (zeekctl cron); script response có log và retry khi gọi API thất bại

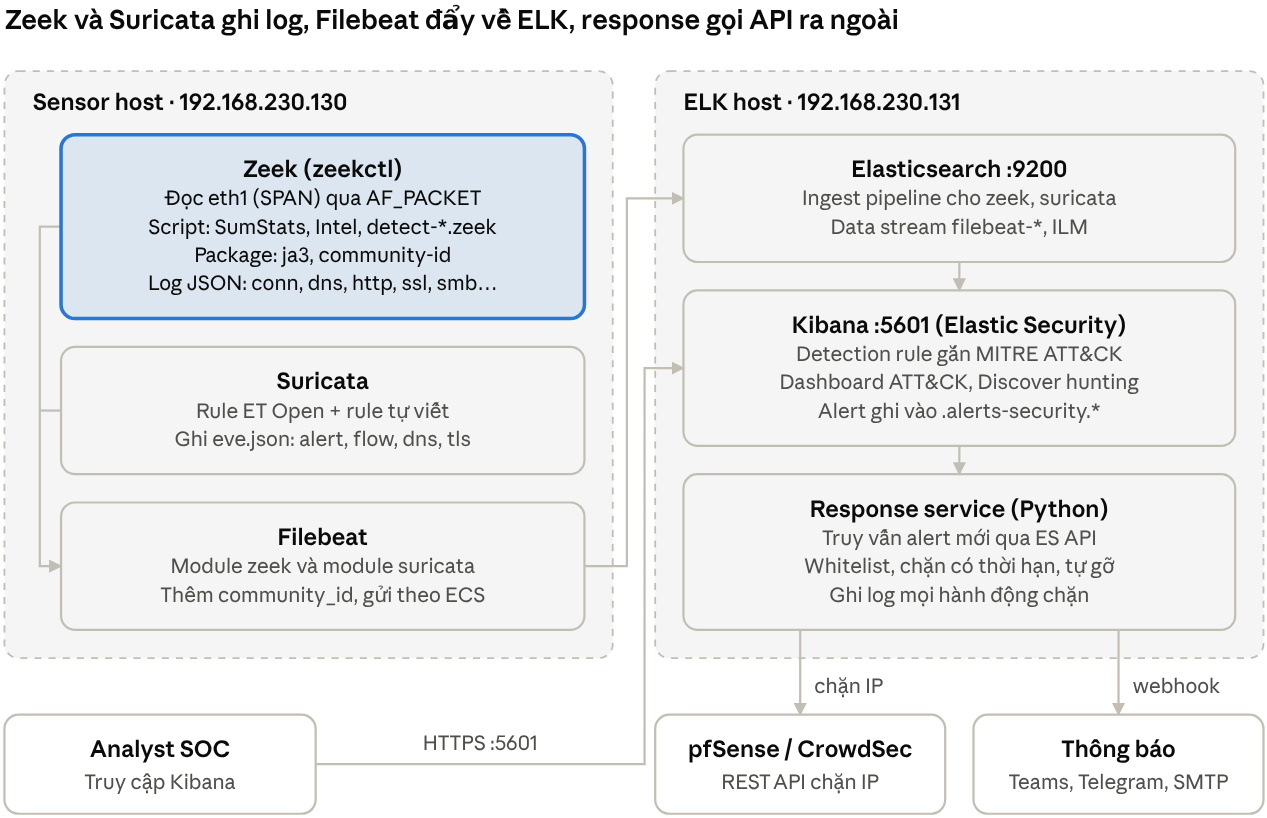
5. Kiến trúc hệ thống

Hệ thống gồm ba lớp chức năng: quản lý log, phát hiện và phản hồi; Zeek năm ở lớp thu thập và cũng tham gia phát hiện theo hành vi.

5.1 Functional architecture

Lớp	Chức năng	Thành phần
Log management	Log collection, parsing (ECS), storage, querying	Zeek, Suricata, Filebeat, Elasticsearch
Detection	Behavior-based (Zeek script), signature-based (Suricata), threat intel (Zeek Intel), MITRE mapping	Zeek, Suricata, Elastic Security rules
Response	Response automation, response manually (playbook), alert	Script Python, pfSense/CrowdSec, Teams/Telegram/email

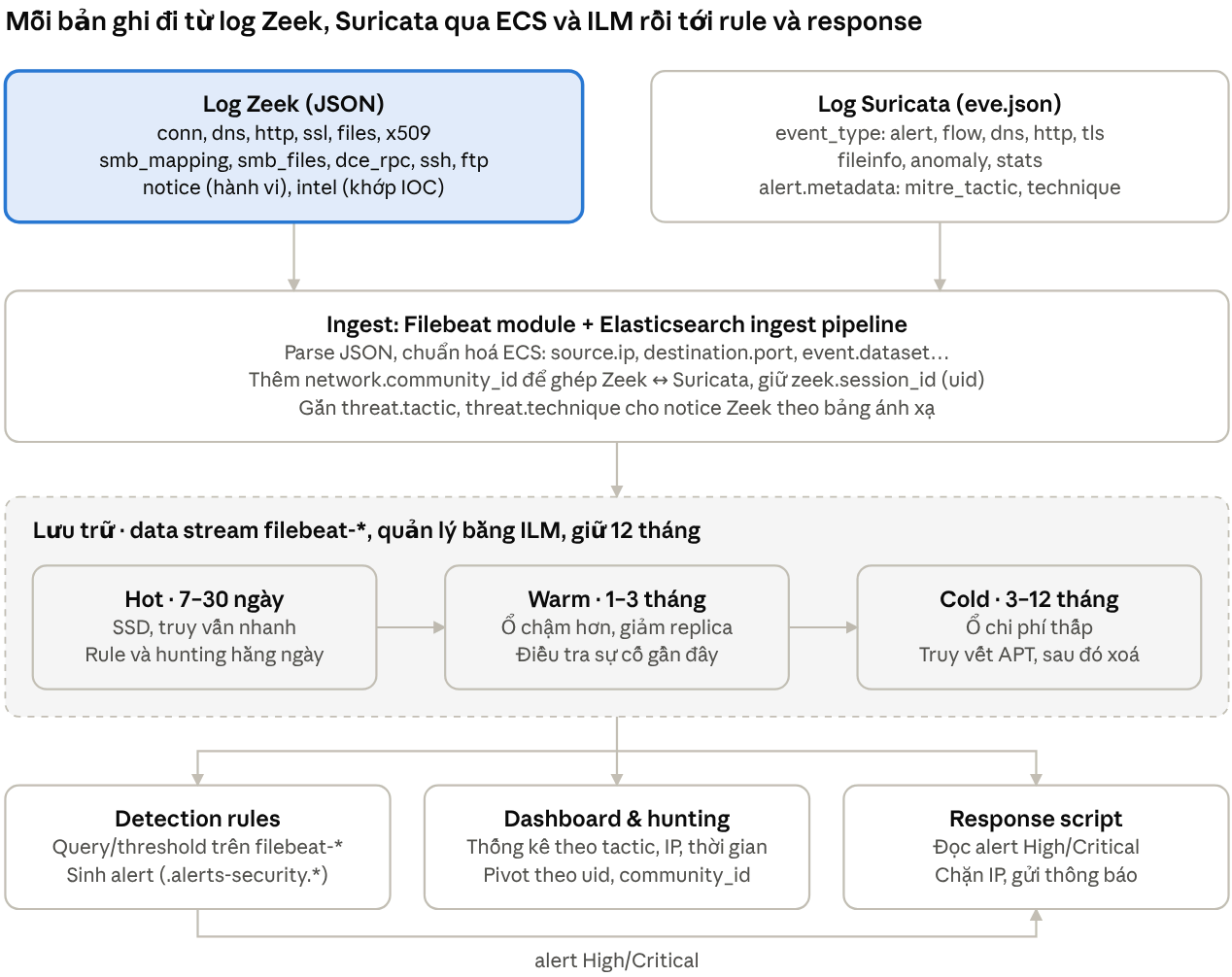
5.2 Application architecture



application architecture · sensor, ELK, hệ thống ngoài

Zeek và Suricata trên sensor ghi log ra đĩa, Filebeat đọc và gửi về Elasticsearch qua HTTPS cổng 9200. Kibana chạy rule sinh alert; response service đọc alert qua API rồi gọi REST API của pfSense/CrowdSec và webhook thông báo.

5.3 Data architecture



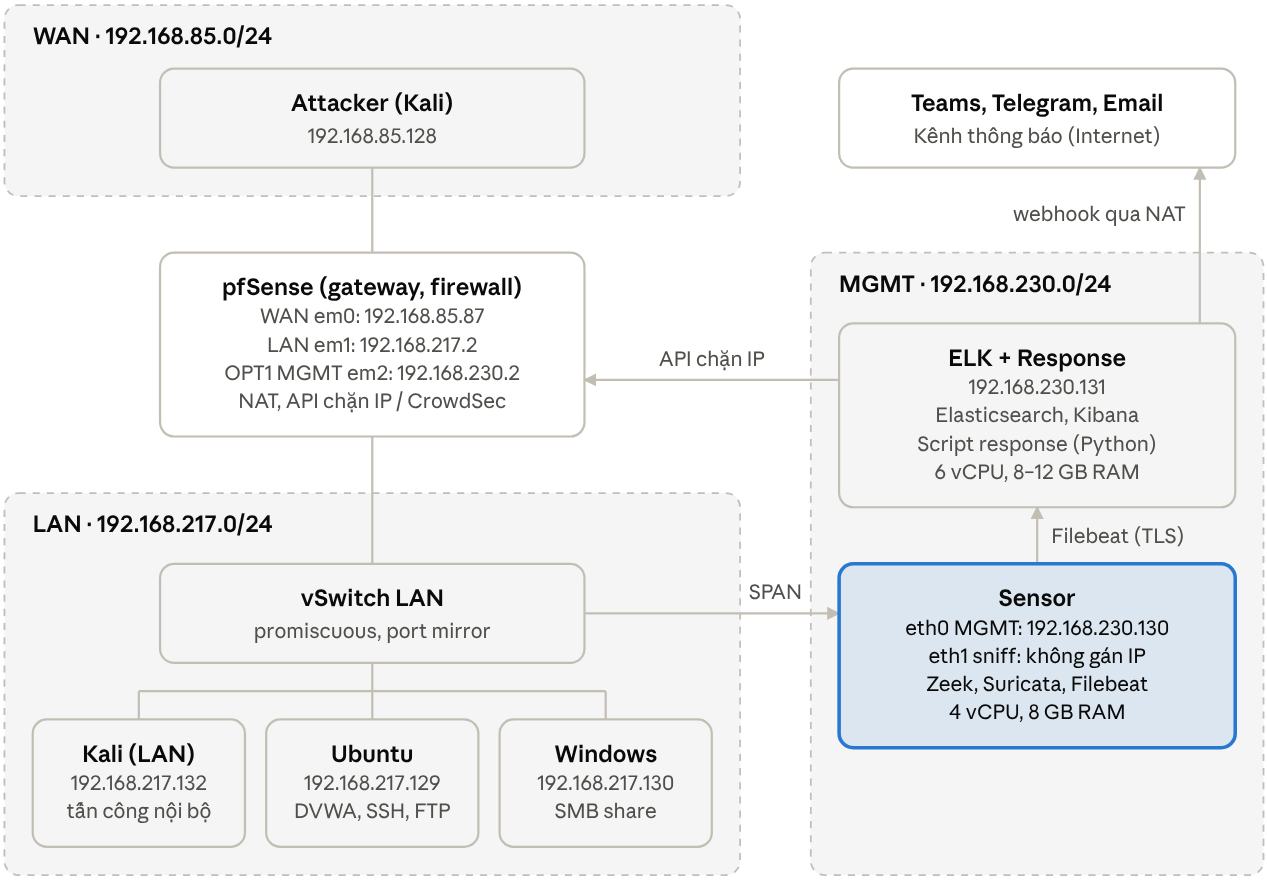
data architecture · 4 tầng: nguồn, ingest, lưu trữ, sử dụng

Log Zeek và Suricata được chuẩn hoá về ECS khi ingest; `network.community_id` và `uid` là hai khoá để ghép các bản ghi của cùng một cuộc tấn công. Dữ liệu chuyển dần từ hot sang cold theo ILM và được giữ 12 tháng.

5.4 Infrastructure architecture

Địa chỉ IP dưới đây là đề xuất, nhóm điều chỉnh theo mạng VMware/VirtualBox thực tế.

Sensor nhận lưu lượng LAN qua cổng mirror, ELK chặn IP qua API pfSense



Đường liền: cáp mạng · Mũi tên: luồng mirror, log và phản hồi · Khung nét đứt: vùng mạng

infrastructure · 3 vùng mạng, 7 máy

Sensor không gán IP trên NIC sniff nên attacker trong LAN không nhìn thấy nó; pfSense có thêm interface OPT1 vào vùng MGMT để script trên ELK gọi API chặn IP mà không đi qua LAN.

VM	Vai trò	Mạng / IP đề xuất
Attacker (Kali)	Tấn công từ WAN và từ trong LAN	WAN 192.168.85.128; LAN 192.168.217.132
pfSense	Gateway, firewall, nhận lệnh chặn IP qua API (hoặc CrowdSec bouncer)	WAN 192.168.85.87; LAN 192.168.217.2; OPT1 MGMT 192.168.230.2
Ubuntu victim	Web server (DVWA), SSH, FTP	192.168.217.129

VM	Vai trò	Mạng / IP đề xuất
Windows victim	SMB share, mục tiêu lateral movement	192.168.217.130
Sensor	Zeek + Suricata + Filebeat; NIC sniff nhận lưu lượng mirror, không gán IP	Management 192.168.230.130
ELK	Elasticsearch, Kibana, script response	192.168.230.131

Tách mạng management (192.168.230.0/24) khỏi LAN giám sát để attacker không chạm được tới ELK và sensor.

6. Kịch bản demo

Sáu kịch bản đi theo thứ tự của một chuỗi tấn công, từ trinh sát đến tuồn dữ liệu, để dashboard MITRE thể hiện được tiến trình của cuộc tấn công. Mỗi kịch bản đều chạy qua cùng một luồng: tấn công → Zeek/Suricata ghi log → Filebeat → Elasticsearch → rule Kibana gắn MITRE → script response chặn IP và gửi thông báo.

#	Kịch bản	Log nguồn	Logic phát hiện	MITRE ATT&CK	Phản hồi
1	Port scan bằng nmap	`conn.log`, `notice.log`	Zeek script dùng SumStats đếm số cổng đích khác nhau / số kết nối REJ, S0 từ một nguồn trong cửa sổ thời gian	TA0007 Discovery – T1046 Network Service Discovery	Cảnh báo
2	Brute force SSH và FTP (hydra)	`ssh.log`, `ftp.log`, `notice.log`	SSH: policy `detect-bruteforcing` sinh notice `SSH::Password_Guessing`; FTP: đếm reply code 530 theo nguồn bằng SumStats	TA0006 Credential Access – T1110 Brute Force	Chặn IP + thông báo
3	Tải malware qua HTTP	`http.log`, `files.log`, `intel.log`, Suricata alert	Zeek tính hash file; Intel Framework khớp hash/domain với danh sách IOC; Suricata bắt chữ ký payload	TA0011 Command and Control – T1105 Ingress Tool Transfer	Chặn IP nguồn tải + thông báo

#	Kịch bản	Log nguồn	Logic phát hiện	MITRE ATT&CK	Phản hồi
4	C2 beaconing	`conn.log`, `ssl.log`	Phân tích chu kỳ kết nối giữa cùng cặp host (độ lệch chuẩn khoảng thời gian nhỏ, kích thước gói đều); đối chiếu JA3 với danh sách client C2	TA0011 Command and Control – T1071.001 Web Protocols, T1573 Encrypted Channel	Cảnh báo + cô lập host (thủ công theo playbook)
5	Lateral movement qua SMB (PsExec / impacket)	`smb_mapping.log`, `smb_files.log`, `dce_rpc.log`	Phát hiện truy cập share `ADMIN$` / `C$`, ghi file `.exe` qua SMB, rồi gọi `svcctl` tạo service từ xa trong một khoảng ngắn	TA0008 Lateral Movement – T1021.002 SMB/Windows Admin Shares; TA0002 Execution – T1569.002 Service Execution	Chặn IP nội bộ + thông báo
6	Data exfiltration qua DNS tunneling (iodine / dnscat2)	`dns.log`	Độ dài subdomain lớn, entropy cao, số query bất thường tới một domain cha trong cửa sổ thời gian	TA0010 Exfiltration – T1048 Exfiltration Over Alternative Protocol; T1071.004 DNS	Chặn IP + thông báo